



АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР

TCPDUMP & LIBPCAP

Tcpdump – это сетевой сниффер, который является очень мощным и гибким, несмотря на отсутствие графического интерфейса. Это безусловно, наиболее часто используемый анализатор сетевых пакетов из командной строки и может быть найден на большинстве операционных систем Unix и Linux. Tcpdump может как захватывать трафик из сети, так и читать существующие файлы захвата.

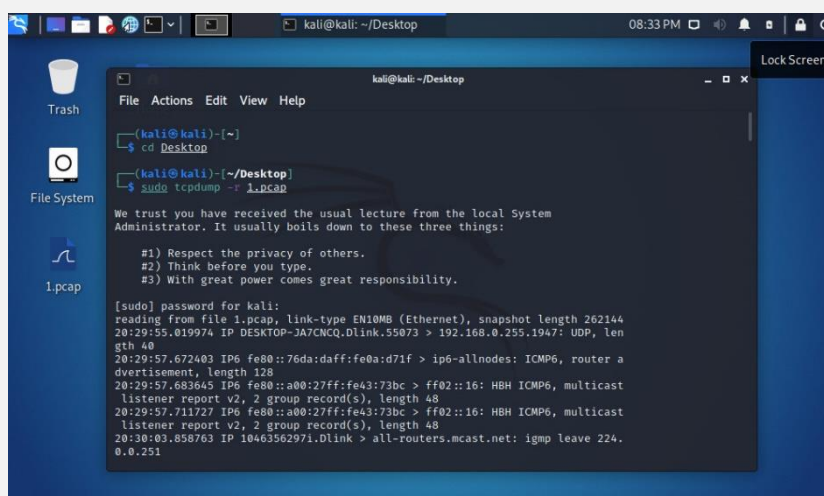
Для того чтобы захватывать трафик из сети, — нужно запустить Tcpdump с помощью **sudo**, параметром **-w** (для записи вывода в файл) и указать имя выходного файла:

```
kali@kali:~$ sudo tcpdump -w ИМЯ ФАЙЛА.pcap
```

Для того чтобы загрузить и проанализировать файл мы можем запустить Tcpdump с помощью **sudo** и открыть файл с параметром **-r**:

```
kali@kali:~$ sudo tcpdump -r ИМЯ ФАЙЛА.pcap
```

В Tcpdump мы загрузим ранее полученный файл с сетевым трафиком (который мы можем получить в ходе нашей работы в браузере с ранее запущенным Tcpdump на захват сетевого трафика: **sudo tcpdump -w 1.pcap**)



Фильтрация трафика

Для фильтрации трафика мы будем использовать **awk** и **sort**. Во-первых, мы будем использовать опцию **-n** (для отображения IP-адреса вместо имени хоста) и **-r** для чтения из нашего файла захвата пакетов. Затем мы можем передать вывод в **awk**, печатая IP-адрес и порт (третье разделенное пробелами поле) и передать его в **sort** и **uniq -c** для сортировки и подсчета количества раз, когда поле появляется в захвате, соответственно. И наконец, мы используем **head**, чтобы отобразить только первые 10 строк вывода:

```
kali@kali:~$ sudo tcpdump -n -r 1.pcap | awk -F" " '{print $3}' | sort | uniq -c | head
```

```
(kali@kali)-[~/Desktop]
$ sudo tcpdump -n -r 1.pcap | awk -F" " '{print $3}' | sort | uniq -c | head
reading from file 1.pcap, link-type EN10MB (Ethernet), snapshot length 262144
 2 192.168.0.104.55073
 4 192.168.0.104.62211
 2 192.168.0.112
11 192.168.0.112.5353
 8 192.168.0.1.41747
 2 fe80::1497:b029:741:d20b
11 fe80::1497:b029:741:d20b.5353
 1 fe80::76da:daff:fe0a:d71f
 2 fe80::a00:27ff:fe43:73bc
 5 Request

(kali@kali)-[~/Desktop]
$
```

Мы можем с уверенностью предположить, что клиентский адрес (192.168.0.112) сделал много запросов к серверу, но чтобы действовать без лишних предположений, мы можем использовать фильтры для более тщательной проверки трафика. Для фильтрации из командной строки мы будем использовать фильтры исходный хост (**src host**) и конечный хост (**dst host**) для вывода только трафика источника и назначения соответственно. Мы также можем фильтровать по номеру порта (**-n port 5353**). Давайте попробуем использовать эти фильтры:

```
kali@kali:~$ sudo tcpdump -n src host 192.168.0.112 -r 1.pcap
kali@kali:~$ sudo tcpdump -n dst host 192.168.0.112 -r 1.pcap
```

```
(kali@kali)-[~/Desktop]
$ sudo tcpdump -n src host 192.168.0.112 -r 1.pcap
reading from file 1.pcap, link-type EN10MB (Ethernet), snapshot length 262144
20:30:03.858763 IP 192.168.0.112 > 224.0.0.2: igmp leave 224.0.0.251
20:30:03.858916 IP 192.168.0.112 > 224.0.0.251: igmp v2 report 224.0.0.251
20:30:03.886968 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0 [3q] [1au] PTR (QU)? _companion-link_tcp.local. PTR (QU)? _homekit_tcp.local. PTR (QU)? _sleep-proxy_udp.local. (112)
20:30:04.900105 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0 [3q] [1au] PTR (QM)? _companion-link_tcp.local. PTR (QM)? _homekit_tcp.local. PTR (QM)? _sleep-proxy_udp.local. (112)
20:30:07.913332 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0 [3q] [1au] PTR (QM)? _companion-link_tcp.local. PTR (QM)? _homekit_tcp.local. PTR (QM)? _sleep-proxy_udp.local. (112)
20:30:12.996966 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0 [4q] [1au] PTR (QU)? _airplay_tcp.local. PTR (QU)? _raop_tcp.local. PTR (QU)? _airplay_tcp.local. PTR (QU)? _raop_tcp.local. (90)
20:30:13.938808 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0 [4q] [1au] PTR (QM)? _airplay_tcp.local. PTR (QM)? _raop_tcp.local. PTR (QM)? _airplay_tcp.local. PTR (QM)? _raop_tcp.local. (90)
20:30:16.933514 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0 [7q] [1au] PTR (QM)? _companion-link_tcp.local. PTR (QM)? _homekit_tcp.local. PTR (QM)? _sleep-proxy_udp.local. PTR (QM)? _airplay_tcp.local. PTR (QM)? _raop_tcp.local. PTR (QM)? _airplay_tcp.local. PTR (QM)? _raop_tcp.local. (151)
20:30:18.291100 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0*- [0q] 1/0/2 (Cache flush) A 192.168.0.112 (116)
20:30:18.393176 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0*- [0q] 1/0/2 (Cache flush) A 192.168.0.112 (116)
20:30:19.296659 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0*- [0q] 2/0/3 (Cache flush) A 192.168.0.112, (Cache flush) A 192.168.0.112 (186)
20:30:21.300459 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0*- [0q] 2/0/3 (Cache flush) A 192.168.0.112, (Cache flush) A 192.168.0.112 (186)
20:30:44.012658 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0 [3q] [1au] PTR (QM)? _companion-link_tcp.local. PTR (QM)? _homekit_tcp.local. PTR (QM)? _sleep-proxy_udp.local. (112)

(kali@kali)-[~/Desktop]
$ sudo tcpdump -n dst host 192.168.0.112 -r 1.pcap
reading from file 1.pcap, link-type EN10MB (Ethernet), snapshot length 262144
20:30:16.360322 ARP, Request who-has 192.168.0.112 tell 192.168.0.1, length 46
20:30:16.360567 ARP, Request who-has 192.168.0.112 tell 192.168.0.1, length 46
20:30:16.360778 ARP, Request who-has 192.168.0.112 tell 192.168.0.1, length 46
20:30:16.361009 ARP, Request who-has 192.168.0.112 tell 192.168.0.1, length 46
```

```
kali@kali:~$ sudo tcpdump -n port 5353 -r 1.pcap
```

```
(kali@kali)-[~/Desktop]
$ sudo tcpdump -n port 5353 -r 1.pcap
reading from file 1.pcap, link-type EN10MB (Ethernet), snapshot length 262144
20:30:03.886968 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0 [3q] [1au] PTR (QU)? _companion-link_tcp.local. PTR (QU)? _homekit_tcp.local. PTR (QU)? _sleep-proxy_udp.local. (112)
20:30:03.887453 IP6 fe80::1497:b029:741:d20b.5353 > ff02::fb.5353: 0 [3q] [1au] PTR (QU)? _companion-link_tcp.local. PTR (QU)? _homekit_tcp.local. PTR (QU)? _sleep-proxy_udp.local. (112)
20:30:04.900105 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0 [3q] [1au] PTR (QM)? _companion-link_tcp.local. PTR (QM)? _homekit_tcp.local. PTR (QM)? _sleep-proxy_udp.local. (112)
20:30:07.913332 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0 [3q] [1au] PTR (QM)? _companion-link_tcp.local. PTR (QM)? _homekit_tcp.local. PTR (QM)? _sleep-proxy_udp.local. (112)
20:30:07.913693 IP6 fe80::1497:b029:741:d20b.5353 > ff02::fb.5353: 0 [3q] [1au] PTR (QM)? _companion-link_tcp.local. PTR (QM)? _homekit_tcp.local. PTR (QM)? _sleep-proxy_udp.local. (112)
20:30:12.996966 IP 192.168.0.112.5353 > 224.0.0.251.5353: 0 [4q] [1au] PTR (QU)? _airplay_tcp.local. PTR (QU)? _raop_tcp.local. PTR (QU)? _airplay_tcp.local. PTR (QU)? _raop_tcp.local. (90)
```

Давайте проверим некоторые пакеты более детально, чтобы увидеть, что мы можем обнаружить еще. Для этого мы воспользуемся опцией **-X**, чтобы вывести данные пакетов в формате HEX и ASCII:


```
kali@kali:~$ sudo tcpdump -nX -r 1.pcap
```

```
(kali@kali) [~/Desktop]
$ sudo tcpdump -nX -r 1.pcap
reading from file 1.pcap, link-type EN10MB (Ethernet), snapshot length 262144
20:29:55.019974 IP 192.168.0.104.55073 > 192.168.0.255.1947: UDP, length 40
0x0000: 4500 0044 0840 0000 4011 efb1 c0a8 0068 E..D.@..@.....h
0x0010: c0a8 00ff d721 079b 0030 25af 7267 6958 .....!...0%.rgiX
0x0020: 4254 5847 7779 6630 5845 3548 3948 504b BTXGwyf0XE5H9HPK
0x0030: 6853 3062 6e34 4450 6643 436f 5332 387a hS0bn4DPfCCoS28z
0x0040: 4769 4541 GiEA
20:29:57.672403 IP6 fe80::76da:daff:fe0a:d71f > ff02::1: ICMP6, router advertisement, length 12
8
0x0000: 6000 0000 0080 3aff fe80 0000 0000 0000 ^.....
0x0010: 76da daff fe0a d71f ff02 0000 0000 0000 v.....
0x0020: 0000 0000 0000 0001 8600 49d2 4040 0000 .....I.@..
0x0030: 0000 0000 0000 0000 0304 40c0 0000 012c .....@....
0x0040: 0000 012c 0000 0000 fd01 0000 0000 0000 ...
0x0050: 0000 0000 0000 0000 1803 0000 ffff ffff .....
0x0060: 0000 0000 0000 0000 0000 0000 0000 0000 .....
0x0070: 0501 0000 0000 05dc 0101 74da da0a d71f .....t....
0x0080: 1f02 0000 ffff ffff 0544 6c69 6e6b 0000 .....Dlink..
0x0090: 1903 0000 ffff ffff fe80 0000 0000 0000 .....
0x00a0: 76da daff fe0a d71f v.....
20:29:57.683645 IP6 fe80::a00:27ff:fe43:73bc > ff02::16: HBH ICMP6, multicast listener report v
2, 2 group record(s), length 48
0x0000: 6000 0000 0038 0001 fe80 0000 0000 0000 ^....8.....
0x0010: 0a00 27ff fe43 73bc ff02 0000 0000 0000 ..'..Cs.....
0x0020: 0000 0000 0000 0016 3a00 0502 0000 0100 .....
0x0030: 8f00 4fc3 0000 0002 0400 0000 ff02 0000 ..0.....
0x0040: 0000 0000 0000 0001 ffa0 068d 0400 0000 .....
0x0050: ff02 0000 0000 0000 0001 ff43 73bc .....Cs.
```

Расширенная фильтрация заголовков

На данном этапе, чтобы лучше изучить запросы и ответы в дампе мы будем искать пакеты, у которых включены флаги PSH и ACK. Все пакеты, отправленные и полученные после трехстороннего рукопожатия, будут иметь флаг ACK. Флаг PSH используется для обеспечения немедленной доставки пакета и обычно используется в интерактивных протоколах прикладного уровня, чтобы избежать буферизации.

На следующем изображении показан заголовок TCP и показано, что флаги TCP определяются, начиная с 14-го байта:

0	8	16	24	32
Source Port				Destination Port
Sequence Number				
Acknowledgment Number				
Data Offset	Reserved	C W R	E C R G	U A P S R S F
				Window Size
Checksum				Urgent Pointer
Options				Padding

Глядя на изображение, мы видим, что ACK и PSH представлены четвертым и пятым битами 14-го байта, соответственно:

CEUAPRSF

WCRCSSYI

REGKHTNN

00011000 = 24 в десятичной СС.

```
kali@kali:~$ echo "$((2#00011000))"
```

24

Мы можем передать это число в Tcprdump с **'tcp[13] = 24'** в качестве фильтра отображения, чтобы указать, что мы хотим видеть только пакеты с установленными флагами ACK и PSH (пакеты данных), представленные четвертым и пятым битами (24) 14-го байта заголовка TCP. Имейте в виду, что индекс массива Tcprdump используемый для подсчета байтов, начинается с нуля, поэтому синтаксис должен быть таким (**tcp[13]**). Комбинация этих двух флагов, покажет нам только HTTP-запросы и ответы. Вот команда, которую мы будем использовать для отображения пакетов с установленными флагами ACK или PSH (опция **-A** - выводить все пакеты в формате ASCII):

```
kali@kali:~$ sudo tcpdump -A -n 'tcp[13] = 24' -r 1.pcap
```

```
(kali@kali)~[~/Desktop]
$ sudo tcpdump -A -n 'tcp[13] = 24' -r 1.pcap 1 x 1
reading from file 1.pcap, link-type EN10MB (Ethernet), snapshot length 262144
21:46:10.693740 IP 192.168.0.170.40832 > 35.166.177.141.443: Flags [P.], seq 3202480689:320248
1206, ack 3801690381, win 502, options [nop,nop,TS val 667008731 ecr 3793634], length 517
E..9..@..@.....#.....1..1.....
'....9.....$/..Beu.X.....q... ^ @..Q... UzGf.. ~.4v.P..r. ..PB ... 1qt.e6.....> ... $......
+./.....,0.
.
...../..5.
.....accounts.firefox.com.....
.....#.....h2.http/1.1.....3.k.i ... ..... \ ... 3|#.....BPj.
% ... A.<5..I.....N.NR.....[w ... :PSJ^..0 .. ;....A ... c9....j.._ ( ..L~..+.....
.....@.....
.....
21:46:10.749581 IP 192.168.0.170.48058 > 35.185.44.232.443: Flags [P.], seq 488497952:48849846
9, ack 2725501107, win 502, options [nop,nop,TS val 1389856954 ecr 3317907079], length 517
E..9ha@..@..j.....#......S.....
R.....>.....Y.....zi.8 ... h..Jb..Q.. ^ ... /\F .p:= ... E.(.ER'.J ... b8.2.....Cr ... $......+
./.....,0.
.
...../..5.
.....www.kali.org.....
.....#.....h2.http/1.1.....3.k.i ... 5.....yWI ... ie..! .. " ... 6....[.
c ... A.Lsc.t.W....J3U'.j50.#.$.....2EFi.) ... S..@..7..X.0.8 ... D..7(/...+.....
.....@.....
.....
21:46:10.891306 IP 35.166.177.141.443 > 192.168.0.170.40832: Flags [P.], seq 1:3663, ack 517,
win 110, options [nop,nop,TS val 3793833 ecr 667008731], length 3662
E ... L@.....#.....1.....6 ... n.....
.9..'......Y...U...CT..B.Q.0.....V.....;^.....3. ...H.N. 0_..b.. |5...../ ...4<PfKAB.G^...../.....
.....0 ... 0..y.....GT..m.\.....~*0.. *..H.....001.0 ...U...
.US1.0 ...U.
..DigiCert Inc1)0'..U... DigiCert TLS RSA SHA256 2020 CA10 ... 210601000000Z..220702235959Z0v1.0
..U...US1.0 ...U...
California1.0 ...U...Mountain View1.0 ...U.
..Mozilla Foundation1.0 ...U...accounts.firefox.com0... "0.. *..H.....0 ..
.....r..[.S ... 4<.k.m....V.... l.....76*=vM.. .1 ... 6.....L.K ... x.o0# ... 8.) ... J.(..9.....~.P.M4
;3V.%]U...0.E"....0.4z..7.....( ... Q.86./..k2.J ... i..0..= ..K..!2p*..d9....d..{%.H...W:U..
..) ... ef.z@zR.q..2P?@ ( .. o.....%~.. $..q....$.w: ... vAP ... 6.....C.eq_.....@0 ..<0 ... U.#.
..0....k.....y.....v..0 ...U.....L.; ... m.....nS
h)H.0....U.....0....accounts.firefox.com..api.accounts.firefox.com..script.accounts.firefox.co
m..verifier.accounts.firefox.com..oauth.accounts.firefox.com..profile.accounts.firefox.com..co
```

Команды, используемые в уроке:

```
kali@kali:~$ sudo tcpdump -w ИМЯ ФАЙЛА.pcap
```

```
kali@kali:~$ sudo tcpdump -r ИМЯ ФАЙЛА.pcap
```

```
kali@kali:~$ sudo tcpdump -n -r 1.pcap | awk -F" " '{print $3}' | sort | uniq -c | head
```

```
kali@kali:~$ sudo tcpdump -n src host 192.168.0.112 -r 1.pcap
```

```
kali@kali:~$ sudo tcpdump -n dst host 192.168.0.112 -r 1.pcap
```

```
kali@kali:~$ sudo tcpdump -n port 5353 -r 1.pcap
```

```
kali@kali:~$ sudo tcpdump -nX -r 1.pcap
```

```
kali@kali:~$ echo "$((2#00011000))"
```

```
kali@kali:~$ sudo tcpdump -A -n 'tcp[13] = 24' -r 1.pcap
```